

Systematic Comparative Taxonomy of Literature on Automated Software Vulnerability Detection

ASTRAVUL: AST-Guided Retrieval-Augmented Generation (RAG) vs. SAST, Graph DL, and Foundation Code LLMs

Department of Computer Science and Engineering, United International University (UIU)

Paper / System	Approach Paradigm	Slicing / Code Representation	RAG	Privacy / Deployment	Key Addressed Limitation / Research Contribution
VulDeePecker (Li et al.)	Deep Learning (BLSTM)	API Call Sinks (Code Gadgets)	No	Local Model Weights	Eliminated coarse full-file noise; isolated library-call dataflow slices.
SySeVR (Li et al.)	Deep Learning (BBiRNN)	Multi-type Slices (AST+CFG+DFG)	No	Local Model Weights	Overcame syntax/control-blindness; discovered 15 open-source zero-days.
DeSign (Zhou et al.)	Graph Neural Net (GGNN)	Composite Code Property Graph	No	Local Model Weights	Captured multi-factor semantics; boosted F1 by 10.5% over token models.
ReVeal (Chakraborty et al.)	Graph DL / Empirical	Function-level Graph Embeddings	No	Local Model Weights	Exposed synthetic benchmark overfitting; precision collapsed to 10% in the wild.
UniXcoder (Guo et al.)	Cross-Modal Pre-training	AST Prefix Sequence + Tokens	No	Local Model Weights	Unified code, comment, and AST representations in a shared 768-d dense vector space.
LineVul (Fu & Tantihamthavorn)	Transformer (CodeBERT)	Sequential Token Self-Attention	No	Local Model Weights	Reduced manual triage effort by > 80% via line-level attention prediction.
CVEfixes (Bhandari et al.)	Curated Security Corpus	Git Commit Diffs	No	N/A	Created ground-truth CVE database (5.5k CVEs, 11k commits); established fix diffs.
DiverseVul (Chen et al.)	Large-Scale C/C++ Corpus	Function-Level Code	No	N/A	Uncovered ~ 48% label noise in Big-Vul; established 18.9k clean C/C++ vulnerabilities.
GPTScan (Sun et al.)	Neuro-Symbolic Hybrid	Lightweight Static Slicing	No	Cloud API (GPT-3.5)	Achieved > 90% precision by combining static candidates with LLM verification.
DeepDFA (Steenhoek et al.)	Neuro-Symbolic / GNN	Compiler Dataflow Bit-Vectors	No	Local Model Weights	Made graph models resilient to adversarial renaming via reaching-def chains.
PDBERT (Liu et al.)	Pre-trained Transformer	Program Dependence Prediction	No	Local Model Weights	Pre-trained on control/data dependencies; achieved $23\times$ higher throughput than Joern.
Vul-RAG (Du et al.)	Retrieval-Augmented LLM	Whole-Function Prompts	Yes	Cloud API (GPT-4)	Injected CWE rules and CVE diffs into LLM context, overcoming patch-blindness (+16–24%).
LLMxCPG (Lekssays et al.)	Neuro-Symbolic Hybrid	Deterministic CPG Graph Slicing	No	Local Fine-Tuned LLM	Slicing pruned 68%–91% code volume, improved LLM F1 by 15%–40%, and boosted robustness.
PrimeVul (Zhang et al.)	Empirical Benchmarking	Function-Level Code Prompts	No	Local & Cloud LLMs	Disproved LLM over-optimism; 7B LLM F1 dropped from 68.3% (Big-Vul) to 3.1% (PrimeVul).
Chasing Shadows (Arp et al.)	Systematic Security Review	Methodological Pitfall Analysis	No	N/A	Formalized 9 research pitfalls across 72 papers; mandated evaluating False Discovery Rate.
ASTRAVUL (Ours) (AST-Guided RAG)	Hybrid Neuro-Symbolic (AST + RAG + LLM)	Tree-sitter AST/DFG Taint Slices (≤ 150 tokens, sinks to sources)	Yes (ChromaDB)	100% Air-Gapped / Local (4-bit Qwen2.5-Coder-7B)	Eliminates 100% SAST false alarms (FDR = 0.0%), resolves LLM patch-blindness via 969 CWEs + patch diffs, prunes tokens by $\geq 70\%$, and guarantees complete code privacy.

Legend: AST: Abstract Syntax Tree; CFG: Control Flow Graph; DFG: Data Flow Graph; CPG: Code Property Graph; RAG: Retrieval-Augmented Generation; FDR: False Discovery Rate (FP/(TP + FP)); SAST: Static Application Security Testing; CWE: Common Weakness Enumeration; CVE: Common Vulnerabilities and Exposures.